RESMI GÜVENLIK MIMARISI & TEKNIK TASARIM RAPORU

Fitness Pro - Rate Limiting & Account Lock Planı

Kimlik Doğrulama Güvenliği, Kademeli IP Engelleyici ve Yönetici Onaylı Hesap Açma Sistemi

SISTEM	DOKÜMAN TIPI	GÜVENLIK SEVIYESI	DURUM / VERSIYON
Fitness Pro Platformu	**Teknik Spesifikasyon**	**Yüksek (Brute-Force Koruması)**	**Onaylandı / v1.0**

1. Amaç ve Genel Bakış

Bu doküman, **Fitness Pro** platformunun kullanıcı giriş (login) mekanizmasını Kaba Kuvvet (Brute-Force) ve Parola Deneme saldırılarına karşı korumak amacıyla tasarlanan güvenlik mimarisini ve uygulama detaylarını içermektedir.

Sistem iki temel savunma katmanına dayanmaktadır: **IP Bazlı Kademeli Rate Limiting** (saldırı hızını yavaşlatmak ve altyapıyı korumak için) ve **Kullanıcı Bazlı Hesap Bloke Mekanizması** (hesap güvenliğini kesin olarak sağlamak için).

1. AŞAMA IP ENGELI	2. AŞAMA IP ENGELI	HESAP BLOKESI
5 Yanlış / 5 Dk	**5 Yanlış / 10 Dk**	**15 Toplam Yanlış**
Geçici IP Cooldown	Uzatılmış IP Cooldown	Admin Onayı Gerekli

2. IP Rate Limiting Kademeleri

IP adresi üzerinden gelen başarısız login denemeleri dinamik olarak takip edilecek ve kademeli bir engelleme (cooldown) mekanizması uygulanacaktır.

AŞAMA	TETIKLEYICI (BAŞARISIZ LOGIN)	SÜREÇ / ENGELLEME SÜRESI	ETKI VE KAPSAM
Aşama 1	5 Kez Başarısız Deneme	**5 Dakika** IP Cooldown	IP adresi 5 dakika boyunca sisteme login isteği gönderemez.
Aşama 2	Bekleme sonrası +5 Başarısız (Toplam 10)	**10 Dakika** IP Cooldown	IP adresi 10 dakika boyunca sisteme login isteği gönderemez.
Aşama 3	Bekleme sonrası +5 Başarısız (Toplam 15)	**Hesap Blokesi**	İlgili kullanıcı hesabı kalıcı olarak bloke edilir. Admin müdahalesi gerekir.

KRITIK GÜVENLIK VE MIMARI NOTLAR:

- **IP Limiti Mantığı:** IP sınırlaması yalnızca saldırı hızını yavaşlatmak (rate limiting) içindir; tek başına hesap güvenliğini sağlamaz.
- **Ağ / NAT Hassasiyeti:** Aynı IP adresini paylaşan (şirket, okul, kamuya açık Wi-Fi vb.) farklı kullanıcıların mağdur olmaması için hesap blokesi yalnızca IP adresine göre yapılmamalı, kullanıcı hesabı seviyesinde ayrı takip edilmelidir.

3. Hesap Bloke Sistemi & Veritabanı Değişiklikleri

Kullanıcı hesabının güvenliğini sağlamak amacıyla veritabanındaki `Users` tablosuna ve yeni oluşturulacak talepler tablosuna aşağıdaki alanlar eklenecektir. Toplam 15 başarısız login denemesine ulaşan hesap otomatik olarak kilitlenir.

3.1. Users Tablosu Genişletme Alanları

VERI ALANI (FIELD)	VERI TIPI	AÇIKLAMA
`FAILEDLOGINATTEMPTS`	`INT`	Kullanıcı bazında biriken başarısız giriş deneme sayısı.
`ISLOCKED`	`BOOLEAN`	Hesabın kilitli olup olmadığını belirtir (`true` / `false`).
`LOCKEDAT`	`DATETIME / NULL`	Hesabın bloke edildiği tarih ve saat damgası.
`LOCKEDREASON`	`VARCHAR / NULL`	Bloke sebebi (Örn: "Güvenlik nedeniyle bloke edildi - 15 Başarısız Giriş").

Not: Bloke edilmiş bir kullanıcı doğru şifreyi girse dahi sisteme giriş yapamaz.

3.2. AccountUnlockRequests Tablosu (Yeni)

ALAN ADI	VERI TIPI	AÇIKLAMA
`ID`	`BIGINT / GUID`	Birincil Anahtar (Primary Key).
`USERID`	`BIGINT / GUID`	Bloke edilen kullanıcının ID'si (Foreign Key).
`REASON`	`TEXT`	Kullanıcının talep oluştururken belirteceği açıklama.
`CREATEDAT`	`DATETIME`	Talebin oluşturulma tarihi.
`STATUS`	`VARCHAR / ENUM`	Talebin durumu: `PENDING`, `APPROVED`, `REJECTED`
`REVIEWEDBY`	`BIGINT / NULL`	Talebi inceleyen Yöneticinin (Admin) UserId'si.
`REVIEWEDAT`	`DATETIME / NULL`	Talebin incelendiği ve karara bağlandığı tarih.
`ADMINNOTE`	`TEXT / NULL`	Yöneticinin onay veya red gerekçesi açıklaması.

4. Başarılı Login & Admin Onay/Red İşlem Akışları

4.1. Başarılı Giriş (Successful Login)

Kullanıcı doğru kimlik bilgileri ile başarılı bir şekilde giriş yaptığında:

- Kullanıcının `FailedLoginAttempts` değeri `0` olarak sıfırlanır.
- IP tarafındaki ilgili başarısız deneme sayacı temizlenir.
- (Aktif bir IP cooldown süresi varsa, başarılı login isteği sunucuya ulaşamayacağı için cooldown mekanizması IP middleware tarafından müstakil yönetilir.)

4.2. Hesap Açma ve Yönetici (Admin) İşlemleri

15 başarısız deneme sonrası bloke olan bir kullanıcı hesabını doğrudan kendisi açamaz. Süreç aşağıdaki gibi işler:

1. **Görsel Bilgilendirme:** Kullanıcı login ekranında hesabının bloke edildiği mesajını görür.
2. **Başvuru Oluşturma:** Kullanıcı "Hesap Açma / Bloke Kaldırma" başvurusu formu doldurur.
3. **Admin Paneli Havuzu:** Oluşturulan talep Admin Paneline `Pending` statüsüyle düşer.
4. **İnceleme ve Karar:** Admin başvuruyu ve güvenlik durumunu inceleyerek işlemi onaylar veya reddeder.

ADMIN KARARI	DB TRANSACTION (VERITABANI GÜNCELLEMELERI)	TALEP KAYDI GÜNCELLEMESI

ONAY (Approved)	`IsLocked = false`
	`FailedLoginAttempts = 0`
	`LockedAt = NULL`
	`LockedReason = NULL`
		`Status = Approved`
		`ReviewedBy = AdminId`
		`ReviewedAt = Now()`
		`AdminNote = Admin Açıklaması`

RED (Rejected)	*Hesap kilitli kalmaya devam eder. Değişiklik yapılmaz.*	`Status = Rejected`
		`ReviewedBy = AdminId`
		`ReviewedAt = Now()`
		`AdminNote = Red Sebebi`

5. Audit / Güvenlik Günlüğü (Security Log)

Sistemdeki tüm kilitlenme, engelleme ve yönetici eylemleri izlenebilirlik ve adli bilişim (forensics) standartlarına uygun şekilde loglanmalıdır.

LOGLANMASI ZORUNLU OLAYLAR:

• Başarısız login denemeleri | • IP Cooldown başlatılması | • 5 Dk / 10 Dk IP kilitleri
• Hesap blokesi gerçekleşmesi | • Unlock başvurusu oluşturulması | • Admin onay / red kararları | • Hesabın tekrar aktif edilmesi

Log Kaydında Bulunması Gereken Asgari Parametreler:

```
{
  "Timestamp": "2026-08-30T17:40:00Z",
  "Event": "ACCOUNT_LOCKED",
  "UserId": "usr_984123",
  "IPAddress": "192.168.1.45",
  "AdminId": null,
  "Status": "Success",
  "Details": "15 adet başarısız giriş denemesi sonrası hesap otomatik bloke edildi."
}
```

6. Backend Mimarisi ve Kod Organizasyonu

Sistemin modüler ve sürdürülebilir olması amacıyla .NET / ASP.NET Core ortamında aşağıdaki klasör ve servis mimarisi önerilmektedir:

```
FitnessPro.Backend/
├── Helpers/
│   └── RateLimitHelper.cs              // IP Bazlı Rate Limiting Mantığı
├── Services/
│   ├── IAccountService.cs              // Login, Başarısız Sayaç & Bloke Kontrolü
│   ├── AccountService.cs
│   ├── IAccountUnlockService.cs        // Başvuru Alma, Listeleme, Onay/Red Servisi
│   └── AccountUnlockService.cs
├── Middlewares/
│   └── RateLimitingMiddleware.cs       // IP Cooldown Kontrolü
└── Program.cs                          // Servis Kayıtları ve Pipeline Yapılandırması
```

Program.cs Konfigürasyon Örneği:

```
// Service Registration
builder.Services.AddFitnessRateLimiting(options => {
    options.FirstStageFailCount = 5;
    options.FirstStageCooldownMinutes = 5;
    options.SecondStageCooldownMinutes = 10;
    options.MaxTotalAttemptsBeforeLock = 15;
});

// Middleware Pipeline
app.UseFitnessRateLimiting();
```

7. Önemli Güvenlik Doktrinleri ve Risk Yönetimi

- **Hesap Varlığı Bilgisi Verilmemeli (Enumeration Koruması):** Giriş hatasında verilen mesajlar "Kullanıcı bulunamadı" veya "Şifre yanlış" şeklinde ayrıştırılmamalı, jenerik (Örn: "Geçersiz kullanıcı adı veya şifre") tutulmalıdır. Yine de hesap kilitlendiğinde uygun bir bilgilendirme ekranına yönlendirme yapılmalıdır.
- **Reverse Proxy ve X-Forwarded-For:** Uygulama Nginx, Cloudflare veya IIS arkasında çalışıyorsa, IP tespiti için `ForwardedHeadersOptions` ayarları doğru yapılmalı ve taklit edilen IP header'larına karşı güvenilir proxy IP'leri beyaz listeye alınmalıdır.
- **Mükerrer Başvuru Koruması:** Bir kullanıcının hali hazırda `Pending` durumunda bir unlock talebi varsa, yeni bir talep oluşturması engellenmelidir.
- **Transaction Bütünlüğü:** Admin onay/red ve veritabanı kilit açma işlemleri veritabanı seviyesinde `DbTransaction` (ACID) içinde yürütülmelidir.
- **Yetkilendirme (Authorization):** Unlock başvurusunu onaylayacak/reddedecek endpoint'ler strictly `[Authorize(Roles = "Admin")]` özniteliği ile korunmalıdır.

8. Son Hedef Özet Tablosu

ADIM / SENARYO	EYLEM / SONUÇ	SISTEM DURUMU
5 Yanlış Login	5 Dakika IP Cooldown	IP Geçici Engelli
+5 Yanlış Login (Toplam 10)	10 Dakika IP Cooldown	IP Uzaatılmış Engelli
+5 Yanlış Login (Toplam 15)	Hesap Bloke Edilir	IsLocked = True

ADIM / SENARYO	EYLEM / SONUÇ	SISTEM DURUMU
Hesap Bloke İken Giriş	Giriş Reddedilir + Başvuru Linki Gösterilir	Hesap Kilitli
Admin Onayı	Hesap Açılır, Sayaçlar Sıfırlanır	IsLocked = False, Counter = 0
Admin Reddi	Hesap Bloke Kalır	IsLocked = True
Başarılı Login	Sayaçlar Temizlenir	Counter = 0